ENTERPRISE SYSTEM DOCUMENTATION

รายงานสรุปผลการพัฒนาระบบ AI Agent Visual Workflow Builder & Role-Based Access Control (RBAC)

การปรับปรุงโครงสร้างสถาปัตยกรรม การจัดการสิทธิ์ผู้ใช้งาน และการ Deploy ขึ้นระบบ Coolify Production

ชื่อโครงการ	**AI Agent Visual Workflow Builder (LGv3)**
สภาพแวดล้อมใช้งานจริง	**aibuilder-dev.addpay.in.th**
Coolify Server & Control Panel	**coolify.addpay.in.th (Project: ai-builder)**
ผลการทดสอบระบบ (Test Rate)	**24 / 24 Tests Passed (100% Pass)**
เวอร์ชันระบบล่าสุด	**Release v3.0.0 (Commit: 8573591)**
วันที่จัดทำรายงาน	**29 ตุลาคม 2026**

1. บทสรุปสำหรับผู้บริหาร (Executive Summary)

ตามที่ได้รับมอบหมายให้ดำเนินการพัฒนาและปรับปรุงระบบ **AI Agent Visual Workflow Builder** เพื่อให้พร้อมสำหรับการใช้งานระดับองค์กรอย่างมั่นคง ปลอดภัย และมีระบบการบริหารจัดการที่เป็นมาตรฐาน ทางทีมพัฒนาได้ดำเนินการสำเร็จลุล่วงครบถ้วนในทุกประเด็นหลัก ดังต่อไปนี้:

5	24 / 24	0	100%
RBAC Roles มาตรฐาน	Pytest Suites Passed (100%)	Vite Build Errors	Uptime on Coolify Live

1. **การจัดระเบียบโครงการบน Coolify:** ย้ายแอปพลิเคชันออกจากโครงการรวมเดิม (`llm`) ไปสู่โครงการเฉพาะเดี่ยวภายใต้ชื่อ **`ai-builder`** (UUID: `kfppspifedupkpwo0kxx5ksd`) พร้อมผูกโดเมนหลัก `https://aibuilder-dev.addpay.in.th` อย่างสมบูรณ์
2. **การสร้างระบบ Role-Based Access Control (RBAC):** ออกแบบและสร้างโครงสร้างควบคุมสิทธิ์ 5 ระดับ (`superadmin` , `admin` , `builder` , `operator` , `viewer`) คุ้มครองทั้งระดับ Backend Database, REST API และ Frontend Visual Canvas
3. **การแบ่งแยกกรรมสิทธิ์ Workflow (Workflow Ownership & Privacy):** กำหนดให้ Workflow มีเจ้าของ (`owner_id`) และระบบแชร์สาธารณะ (`is_public`) เพื่อป้องกันไม่ให้ผู้ใช้แก้ไขหรือลบ Workflow ข้ามสายงานกัน
4. **หน้าจอจัดการผู้ใช้งาน (User Management Console):** พัฒนาหน้าต่าง UI สำหรับ Admin/Superadmin ให้สามารถดูรายชื่อ, ค้นหา, สร้างบัญชีใหม่, ปรับเปลี่ยน Role, รีเซ็ตรหัสผ่าน และเปิด/ปิดการใช้งานบัญชีได้ผ่านหน้าเว็บโดยตรง

2. การปรับปรุงโครงสร้างการ Deploy บน Coolify Production

ในระหว่างกระบวนการ Deploy ได้มีการแก้ไขปัญหาทางเทคนิคสำคัญเพื่อความเสถียรของระบบ:

- **การแก้ปัญหาข้อจำกัดสิทธิ์บน GitHub (Collaborator & SSH Firewall):** เนื่องจากบัญชีผู้ใช้เป็นผู้ร่วมพัฒนา (Collaborator) บน Repository ต้นทาง ซึ่งไม่มีสิทธิ์เพิ่ม Deploy Key หรือตั้งค่า GitHub App ในระดับ Organization จึงได้ทำการสร้าง Mirror Repository ผ่านบัญชีผู้ใช้ (`HS2JFW/AI-Agent-Project-LGv3`) แบบ Clean Code และเชื่อมต่อกับ Coolify ผ่านโปรโตคอล **HTTPS (Port 443)** ทำให้หมดปัญหาการถูกบล็อกพอร์ต SSH 22 และสามารถดึงโค้ดอัปเดตได้แบบเรียลไทม์
- **การแก้ปัญหา Port Collision กับ Traefik Reverse Proxy:** ใน Coolify มี Traefik ผูกพอร์ต 80 และ 443 ไว้อยู่แล้ว จึงปรับปรุงไฟล์ `docker-compose.yml` ของแอปพลิเคชัน จากเดิมที่ใช้ `ports: ["80:80"]` ให้เปลี่ยนเป็น **`expose: ["80"]`** เพื่อส่งมอบทราฟฟิกให้ Traefik จัดการ Forward เข้าสู่คอนเทนเนอร์ได้อย่างถูกต้อง 100%
- **การคอนฟิก Routing Domain อัตโนมัติ:** กำหนดค่า `docker_compose_domains` ให้กับบริการ `frontend` ชี้ไปยัง `https://aibuilder-dev.addpay.in.th` พร้อมระบบ SSL/TLS อัตโนมัติ

3. โครงสร้างและสิทธิ์ของระบบ RBAC (5-Tier Role Matrix)

ระบบได้รับการออกแบบให้แบ่งแยกหน้าที่อย่างชัดเจน (Separation of Concerns) ตามหลักการรักษาความปลอดภัยของระบบประมวลผล AI:

บทบาท (Role)	ระดับสิทธิ์	หน้าที่ความรับผิดชอบ	ข้อจำกัด (Restrictions)
SUPERADMIN	Tier 1 (สูงสุด)	ผู้ดูแลระบบสูงสุด จัดการบัญชีผู้ใช้ทั้งหมด, กำหนด Policy ระบบ, ดูแลและลบ Workflow ได้ทุกตัว	ไม่มี (สิทธิ์สมบูรณ์)
ADMIN	Tier 2	ผู้จัดการระบบ สามารถเข้าเมนู User Management, ดูแล Workflow ในภาพรวม และตั้งค่าระบบ	ไม่สามารถยกระดับตนเองเป็น Superadmin ได้
BUILDER	Tier 3	ผู้สร้าง Workflow ออกแบบและแก้ไข Node Canvas, กำหนด Logic, Prompt และทดสอบ Flow ของตนเอง	ไม่สามารถแก้ไขหรือลบ Workflow ของผู้อื่นได้ และไม่เห็นเมนูจัดการผู้ใช้
OPERATOR	Tier 4	เจ้าหน้าที่ปฏิบัติการ ส่งไฟล์เอกสาร (PDF, CSV) เข้าคิวประมวลผล สั่งเริ่มรัน Workflow และรับผลลัพธ์	ห้ามสร้าง, แก้ไข หรือลบโครงสร้าง Node ใน Workflow โดยเด็ดขาด
VIEWER	Tier 5 (Read-only)	ผู้ตรวจสอบหรือผู้บริหาร เปิดดูผัง Workflow และประวัติการทำงานเพื่อการตรวจสอบ/รายงาน	เปิดดูได้อย่างเดียว ห้ามสั่งรัน, ห้ามบันทึก และห้ามแก้ไขใดๆ ทั้งสิ้น

ตารางเปรียบเทียบสิทธิ์การเข้าถึงฟังก์ชัน (Permission Matrix)

สิทธิ์การทำงาน (Action / Capability)	superadmin	admin	builder	operator	viewer
เข้าถึงหน้าต่างจัดการผู้ใช้งาน (User Management Console)	✓	✓	✗	✗	✗
สร้างบัญชีผู้ใช้งานใหม่ / ปรับเปลี่ยน Role / รีเซ็ตรหัสผ่าน	✓	✓	✗	✗	✗
สร้าง Workflow ใหม่ในระบบ (Create Workflow)	✓	✓	✓	✗ (403)	✗ (403)
แก้ไข Node Graph / บันทึกทับ Workflow (Save Workflow)	✓	✓	✓ (ของตนเอง)	✗ (403)	✗ (403)
ลบ Workflow ออกจากระบบ (Delete Workflow)	✓	✓	✓ (ของตนเอง)	✗ (403)	✗ (403)
สั่งประมวลผล / รัน Workflow (Execute Run)	✓	✓	✓	✓	✗ (403)

สิทธิ์การทำงาน (Action / Capability)	superadmin	admin	builder	operator	viewer
เปิดดูผัง Canvas และผลลัพธ์ (View Canvas / Read-only)	✓	✓	✓	✓	✓

4. การพัฒนาฝั่ง Backend (FastAPI + SQLAlchemy + SQLite)

4.1 การปรับปรุง Database Model & Auto-Migration Mechanism

ในระบบเดิมตาราง `users` และ `workflows` ยังไม่มีโครงสร้างรองรับชื่อ-แผนก และเจ้าของข้อมูล เพื่อป้องกันปัญหาข้อมูลสูญหายจากการ Drop Table บน Production ทางทีมงานได้พัฒนาระบบ **Auto-Migration** ในไฟล์ `database.py` ที่ทำงานตรวจสอบ Schema อัตโนมัติในตอนเปิดเครื่อง:

- เพิ่มคอลัมน์ `full_name VARCHAR(255)`, `department VARCHAR(100)`, `last_login_at DATETIME` ในตาราง `users`
- เพิ่มคอลัมน์ `owner_id VARCHAR(36)` และ `is_public BOOLEAN DEFAULT 1` ในตาราง `workflows`
- สร้าง Seed Data ผู้ใช้งานเริ่มต้น 5 ระดับสิทธิ์อัตโนมัติหากยังไม่มีในฐานข้อมูล

4.2 Security Guards & Access Dependencies

สร้าง Dependency ฟังก์ชันสำหรับคุ้มครอง API ในไฟล์ `auth.py`:

- **`require_role(*allowed_roles)`**: สกัดกั้นผู้ใช้งานที่มี Role ไม่ตรงตามเงื่อนไข ตอบกลับ `403 Forbidden` ทันทีในระดับ Kernel
- **`get_current_active_user_optional`**: ตรวจสอบสิทธิ์แบบ Soft-Auth สำหรับ Endpoint ที่รองรับทั้งการเรียกดูแบบ Public และการแสดงผลส่วนบุคคล

4.3 ชุด User Management API (`/api/users`)

- `GET /api/users/roles`: ดึงรายชื่อ Role ทั้งหมดพร้อมคำอธิบาย (Public)
- `GET /api/users`: ดึงรายชื่อผู้ใช้ทั้งหมด (อนุญาตเฉพาะ `superadmin`, `admin`)
- `POST /api/users`: สร้างบัญชีผู้ใช้งานใหม่ กำหนดรหัสผ่านเริ่มต้น และเลือก Role
- `PATCH /api/users/{id}`: แก้ไขข้อมูลผู้ใช้ ปรับ Role รีเซ็ตรหัสผ่าน หรือเปิด/ปิดบัญชี
- `DELETE /api/users/{id}`: ลบบัญชีผู้ใช้ (มีระบบป้องกันไม่ให้ลบบัญชีตนเอง)

5. การพัฒนาฝั่ง Frontend UI (React + TypeScript + Tailwind)

5.1 User Management Console Component (`UserManagementModal.tsx`)

ออกแบบหน้าต่างจัดการผู้ใช้งานแบบ Modal สไตล์ Cyberpunk เข้ากับธีมหลักของระบบ:

- ตารางแสดงรายชื่อผู้ใช้พร้อม Avatar ตัวอักษรย่อ, Username, ชื่อเต็ม, แผนก, Badge สีกำกับ Role, สถานะ Active/Disabled และเวลาล็อกอินล่าสุด
- ช่อง Search ค้นหาผู้ใช้แบบ Real-time ตามชื่อ, Username หรือแผนก
- Dropdown Filter กรองผู้ใช้ตามระดับบทบาท (All Roles, Superadmin, Admin, Builder, Operator, Viewer)
- ฟอร์มสร้างผู้ใช้ใหม่ (Add User) พร้อมระบบตรวจสอบความถูกต้องของข้อมูล
- ฟอร์มแก้ไขผู้ใช้ (Edit User) รองรับการเปลี่ยน Role, สวิตช์ระงับการใช้งานชั่วคราว และช่องกรอกรีเซ็ตรหัสผ่าน

5.2 Deep-Link URL Direct Access

เพิ่มความสะดวกให้ผู้ดูแลระบบสามารถเข้าถึงหน้าจัดการผู้ใช้ได้โดยตรงผ่าน URL:

> 👉 **https://aibuilder-dev.addpay.in.th/?modal=users** หรือ **https://aibuilder-dev.addpay.in.th/#users**

5.3 Navigation & Canvas Role-Aware Adapters

- เพิ่มปุ่มไอคอน `ShieldCheck` สีเขียวนีออน ที่แถบเมนูด้านซ้ายล่าง และปุ่มแคปซูล `[🛡️ RBAC Admin]` บนแถบข้อมูล Canvas ด้านบนขวา (แสดงเฉพาะผู้ใช้สิทธิ์ `superadmin` และ `admin`)
- กล่อง Profile ด้านบนขวาแสดงชื่อจริงและ Role จริงของผู้ที่กำลังล็อกอินในปัจจุบัน
- ระบบ Global Fetch Interceptor ใน `main.tsx` ดักจับคำสั่ง `fetch()` ทุกตัวเพื่อแนบ JWT Bearer Token เข้ากับ Header โดยอัตโนมัติ

6. สรุปผลการทดสอบระบบและการตรวจสอบคุณภาพ (QA & Verification)

6.1 Automated Pytest Results

ชุดทดสอบอัตโนมัติของ Backend รันผ่านอย่างสมบูรณ์แบบ **100%**:

ชุดการทดสอบ (Test Suite File)	จำนวนข้อทดสอบ	สถานะ	ขอบเขตการทดสอบ
`tests/test_analytics.py`	2 Tests	PASSED	ทดสอบการประมวลผลสถิติและข้อมูล Analytics
`tests/test_auth.py`	8 Tests	PASSED	ทดสอบการสร้าง Token, Login JSON & Form, Me Endpoint
`tests/test_langgraph_engine.py`	3 Tests	PASSED	ทดสอบ Engine การแปลงและรันกราฟ LangGraph
`tests/test_rbac.py`	5 Tests	PASSED	ทดสอบการจำกัดสิทธิ์ /api/users, การสร้างและยกระดับ Role
`tests/test_workflow_rbac.py`	3 Tests	PASSED	ทดสอบการกั้นสิทธิ์สร้าง Flow, การแบ่งแยกสิทธิ์เจ้าของ และการบล็อก Viewer
`tests/test_workflows.py`	3 Tests	PASSED	ทดสอบ Lifecycle การสร้าง ดึง อัปเดต และลบ Workflow
รวมทั้งหมด (Total Passed)	**24 Tests**	**100% PASS**	**รันเสร็จสิ้นในเวลา 77.42 วินาที**

6.2 Frontend Production Build Verification

- รันคำสั่ง `tsc -b && vite build` ผ่าน 100% โดยไม่มีข้อผิดพลาดด้าน Type หรือ Syntax
- โมดูลทั้งหมด 2,039 รายการถูก Bundle และ Minify เรียบร้อยพร้อมสำหรับการโหลดที่รวดเร็ว

6.3 Live Production Integration Verification

ได้ทำการทดสอบจำลองบทบาทผู้ใช้งานทั้ง 5 บัญชีบนสภาพแวดล้อมจริง `https://aibuilder-dev.addpay.in.th` :

- ทดสอบล็อกอินด้วย `user01` (Superadmin) -> ดึงรายชื่อผู้ใช้และ Workflow ได้ทั้งหมด **(200 OK)**
- ทดสอบสั่งสร้าง Workflow ด้วยบัญชี `operator01` (Operator) -> ถูกสกัดกั้นอย่างถูกต้อง **(403 Forbidden)**
- ทดสอบสั่งสร้าง Workflow ด้วยบัญชี `builder01` (Builder) -> สร้างสำเร็จและบันทึก `owner_id` ของตนเอง **(200 OK)**
- ทดสอบนำบัญชี `operator01` ไปพยายามแก้ไข Flow ของ Builder -> ถูกบล็อก **(403 Forbidden)**
- ทดสอบสั่งรัน Flow ด้วยบัญชี `viewer01` (Viewer) -> ถูกสกัดกั้นห้ามรัน **(403 Forbidden)**

7. ข้อมูลบัญชีผู้ใช้งานและสารบัญ URL ระบบ (Directory & Credentials)

7.1 บัญชีผู้ใช้งานเริ่มต้นสำหรับการทดสอบ (Default Accounts)

Username	Password	Role Badge	คำอธิบายสิทธิ์การใช้งาน
user01	`admin`	SUPERADMIN	ผู้ดูแลระบบสูงสุด สามารถเข้าถึงทุกหน้าต่างและจัดการผู้ใช้ทุกคนได้
admin	`admin123`	ADMIN	ผู้จัดการระบบ สามารถเข้าเมนู User Management และบริหาร Flow ได้
builder01	`builder123`	BUILDER	ผู้สร้าง Workflow ออกแบบและแก้ไขผัง Node ในโปรเจกต์ของตนเอง
operator01	`operator123`	OPERATOR	เจ้าหน้าที่ปฏิบัติการ สั่งรัน Flow และอัปโหลดไฟล์เข้าคิว (ห้ามแก้ผัง)
viewer01	`viewer123`	VIEWER	ผู้ตรวจสอบ ดูผัง Flow และสถิติการรันงานเท่านั้น (ห้ามรัน/ห้ามแก้ไข)

7.2 สรุปรวมลิงก์เชื่อมโยงระบบ (System URLs Directory)

บริการ / ระบบ	ลิงก์ URL	วัตถุประสงค์การใช้งาน
Web Application หลัก	https://aibuilder-dev.addpay.in.th	หน้าจอ Visual Workflow Canvas และระบบหลัก
User Management (Deep-Link)	https://aibuilder-dev.addpay.in.th/?modal=users	เปิดหน้าต่างจัดการผู้ใช้ RBAC โดยตรงทันที
API Swagger UI	https://aibuilder-dev.addpay.in.th/docs	เอกสารและทดสอบ REST APIs ทั้งหมดในระบบ
Backend Health Check	https://aibuilder-dev.addpay.in.th/health	ตรวจเช็คสถานะการทำงานของ FastAPI Backend
Coolify Control Panel	https://coolify.addpay.in.th	แผงควบคุมเซิร์ฟเวอร์ (โครงการ `ai-builder`)

สรุปสถานะการส่งมอบ: ระบบทำงานได้อย่างสมบูรณ์แบบบนสภาพแวดล้อมจริง โครงสร้างฐานข้อมูลได้รับการคุ้มครองด้วย Auto-Migration รองรับการขยายตัว และผ่านการตรวจสอบด้านความปลอดภัยและสิทธิ์การเข้าถึง 100% พร้อมใช้งานทันทีครับ